AI-assisted security review

Reviewed 2026-09-14 by the implementing agent. Scope: TON escrow/fixtures, Compact bridge and pool, SDK, signers, relay/persistence and deployment workflows. This is not an independent audit. The release remains synthetic-test-only; mainnet execution is disabled.

Implemented findings

Quorum could redirect arbitrary recovered collateral
Removed unrestricted recovery opcode. Refunds require an authenticated recorded sender/amount and cannot select another payee. TVM tests cover malformed deposits, capacity overflow, replay and unknown refund IDs.

Forged fixture-wallet bounce could inflate balance
Outgoing query IDs bind amount and expected recipient wallet. Only matching bounced messages restore funds. Tests inject forged bounce messages.

A downstream recipient failure could strand a release
Supplied fixture wallet reports an authenticated failure to its owner; escrow restores the exact pending release/refund. TVM test forces destination overflow, processes the real bounce, restores backing and successfully retries. This callback is fixture-specific.

Midnight maintenance key could alter verifier rules
New deployments use an empty authority committee with threshold 1. Deployment reads back this impossible authority. Final local deployment and proof-backed calls have executed successfully. Older development deployments are superseded, not retroactively made immutable.

Invalid curve points and signature scalar malleability
Constructor and claims reject identity/non-subgroup points; response decomposition is constrained and bounded below the subgroup order. SDK rejects noncanonical responses. Tests cover torsion, identity, invalid points and response plus subgroup order. `upgradeFromTransient` truncates and is intentionally not used for full scalar range validation.

Excess pool deposits could donate value unexpectedly
Subsequent paired deposits require the exact rounded-up reserve ratio. Seeded swap tests check nondecreasing product; tests reject donation, slippage and dishonest quotient witnesses.

Operator could sign conflicting payloads without durable policy
SQLite signing ledger binds IDs to digest, reserves daily quota atomically, limits per-transfer amounts and checks a stop file before signing. Keys must match the configured slot. Tests cover retry, quota, equivocation and pause.

Cross-network state and stale artifacts
Separate network state directories; conflicting environments rejected; owner-only secret readers; stale Compact fingerprint rejects build/test. Deployment plans cannot silently change a prior route.

Ambiguous sends/restarts
Persist signed bytes before broadcast; compare-and-set journal stages; no blind replacement sends. Wallet synchronization is checkpointed. Transaction IDs, wallet sequence changes and recipient delivery are distinct.

Missing transfer notification
Fixture wallet now rejects zero/insufficient notification gas. TVM tests verify the sender balance and deposit count stay unchanged.

Missing recipient finality validation
Added source/recipient jetton message-hash matching and successful recipient transaction checks at an older masterchain snapshot. Trusted RPC remains a declared assumption.

Linux bootstrap did not find compiler
Corrected target directory; GitHub-hosted Linux build/tests/package workflow passed after the fix.

The current `npm audit` scan reported zero known dependency vulnerabilities. That database result is not evidence that dependencies contain no vulnerabilities.

Remaining boundaries and production blockers

HIGH - Committee and RPC trust. Two compromised/colluding committee members can mint unbacked representations or authorize fraudulent releases. Rate limits reduce exposure but do not remove that authority. The demonstration uses three keys on one development host. Independent custodians, independent trusted infrastructure and explicit trust-model acceptance are required for external use. A light-client bridge is a different implementation.

HIGH - Specialist cryptographic review. The custom Jubjub Schnorr transcript uses a 248-bit challenge and explicit subgroup/scalar constraints. Tests and real proofs exercise correctness for selected inputs; they do not establish Fiat-Shamir security or complete circuit soundness. Obtain independent cryptographic review before valuable assets.

HIGH - Actual production assets are unspecified. The supplied wallet has an additional pending dictionary and a custom failure notification. It is not a drop-in production USD1 adapter or issuer-approved token. Production adapters, freeze/upgrade behavior and asset-specific lifecycle tests cannot be specified truthfully until the actual masters/code/issuers are agreed. Mainnet remains disabled.

MEDIUM - Missing notifications and storage/liveness. The supported fixture transfer path requires notification gas. Direct issuer minting into an escrow, or unsupported production jettons without notification, can still create inventory outside the receipt/refund ledger. No arbitrary surplus-drain path is provided. Operators must prevent this in supported clients and agree a reviewed asset-specific recovery design before production. Receipt, release and pending-history maps retain records and grow with usage. Cap amounts, provide gas/storage reserves and measure sustainable load. Fixed committee replacement requires an accounted new-route migration.

MEDIUM - Operations and acceptance. Manual CLI tools and trace primitives do not supply an always-running watcher, hosted signer service, paging contract, SLA or an appointed operator. Gas/DUST, independent custody, disaster recovery and operating duration must be assigned. Stop files prevent new signatures but cannot cancel existing signatures. User funds and pending journals must remain accounted for during shutdown.

MEDIUM - Privacy/economics. Bridge transfers and balances are unshielded/linkable. The notes starter is local-memory software with a salted commitment, not an on-chain private-note protocol. First LP sets the unit ratio; integer rounding and price movement affect returns. No dollar peg, anonymity or principal guarantee is supplied. Decimals, test liquidity amounts and any further privacy deliverables require scope acceptance.

LOW - Independent reproduction and delivery artifacts. Hosted CI and local clean installs are useful but are not the agreement's independent developer acceptance. Obtain the separately performed build, demonstration recording, approved PDF/IPFS reference and written Foundation acceptance.

Validation interpretation

See validation and the source/artifact hashes in build manifest. TVM tests exercise contract execution; local Midnight evidence exercises actual proofs and ledger finalization. Public two-chain completion must be supported by its own `testnet-evidence.json` with final recipient delivery. A script, submitted transaction or faucet acknowledgment alone is insufficient.

Primary references

TON contract security: authenticate messages and account for asynchronous effects.

Jetton lifecycle and transfer flow: wallet forwarding, notification and failure behavior.

Midnight Schnorr example: transcript implementation reference, not an audit certificate for this code.

Midnight wallet synchronization work: event replay and alternative Merkle-tree synchronization; live network/toolchain compatibility must be verified.

Release decision: deliver as reviewed test-asset software with these limitations and actual evidence. Do not label it audited, production-ready, privately anonymous or contractually accepted.